Security & Privacy (HIPAA) Risk Assessment – Genie One

Document control	
Document ID	RA-TRB-2026-005
Document type	Security & Privacy Risk Assessment
Date	2026-07-21
Status	Approved
Review IDs	TRB-2026-005
Feature keys	Genie One@SQL & BI Analytics
Classification	Internal – Synthetic Sample

> Acme Health Plan is fictional. This is a synthetic sample document for the Databricks Feature Tracker.

Feature Name: Genie One (Databricks SQL Generator)
Review ID: TRB-2026-005
Assessment Date: July 21, 2026
Assessed By: Enterprise Architect
Overall Risk Level: Moderate (mitigated to Low via conditions)
PHI-Eligible (Conditions Met)? Conditional Yes

---

1. Executive Summary

Genie One is a natural-language SQL generator. Users ask questions in English; Genie generates SQL and returns results. Feature is GA. Risk centers on PHI leakage in user prompts (e.g., "Show me all patients with SSN 123-45-6789") and result set privacy (e.g., low-count aggregates revealing cohort members). Prompt/data handling to be verified during condition execution.

With conditions (query logging, response masking, training), risk is acceptable for PHI use.

---

2. Risk Assessment Context

2.1 System Boundaries

In scope:
- Genie One query generation and execution within Databricks workspace
- Natural-language prompts entered by users
- Query results displayed in Genie UI

Out of scope:
- Databricks infrastructure security (inherited AWS controls)
- User's laptop or network security

2.2 Data Classification

Data Types: Member demographics, claims (medical claims, mental health, pharmacy), membership status
Sensitivity: PHI (HIPAA-regulated)
Volume: ~3M member records; ~50M annual claims
Frequency: Ad-hoc queries by 5-10 analytics users daily

---

3. Threat & Vulnerability Analysis

3.1 Threat Sources

Threat Source	Likeli-hood	Impact	Notes
User (accidental PHI leakage in prompt)	High	High	E.g., "Show me John Doe's claims" in natural-language prompt
User (phishing/credential theft)	Medium	High	Attacker queries member data via compromised account
Genie (LLM response contains PHI)	Medium	Medium	Response summarizes low-count aggregates revealing cohorts
Infrastructure (query interception)	Low	High	Unlikely in VPC; but TLS ensures encryption in transit
Insider (misuse)	Low	High	Authorized user intentionally exports data

3.2 Vulnerability Assessment

Administrative Safeguards (45 CFR § 164.308)

Control	Re-quired?	Imple-men-ted?	Evidence	Gap
Security Management Process	Yes	[x]	Feature reviewed per TRB charter	None
Workforce Security	Yes	[x]	UC permissions; user roles	Role assignment must be audited annually
Information Access Management	Yes	[~] Partial	UC row filters enforce basic access	**Gap: Genie doesn't enforce additional masking for sensitive columns (SSN, DOB) if user has table access**
Security Awareness Training	Yes	[ ]	Not yet in place	**COND-005-4: Training required**
Security Incident Procedures	Yes	[x]	Breach response plan exists; includes Genie queries	None
Contingency Planning	Yes	[x]	Backup/recovery in place	None

Technical Safeguards (45 CFR § 164.312)

Control	Required?	Imple-men-ted?	Evidence	Gap
Access Control (Authentication)	Yes	[x]	SSO + MFA to Databricks	None
Access Control (Authorization)	Yes	[~] Partial	UC permissions + row filters	**Gap: COND-005-2 requires testing**
Audit Controls & Logging	Yes	[~]	Query audit logs exist in system tables	**COND-005-1: Need explicit logging of**

Control	Required?	Imple-men-ted?	Evidence	Gap
				Genie prompts + responses
Integrity Controls	Yes	[x]	Query logs immutable; system tables append-only	None
Transmission Security	Yes	[x]	TLS 1.2 enforced for all Databricks traffic	None
Encryption (At Rest)	Addressable	[x]	AWS KMS encryption on data	None

Physical Safeguards (45 CFR § 164.314)

Control	Re-quired?	Imple-men-ted?	Evidence	Gap
Facility Access	Yes	[x]	AWS data center controls (inherited)	None
Workstation Security	Yes	[~]	Corporate network only; VPN required for remote	Assumes laptop security (user responsibility)
Device & Media Controls	Yes	[~]	No direct export from Genie UI; but users can copy-paste	**Risk: Users can paste results into email/slack. Mitigated by training & monitoring.**

4. Risk Analysis

4.1 Identified Risks

#	Threat	Vulnerability	Likeli-hood	Impact	Risk Score	Mitigation
1	User enters PHI in prompt	Genie logs natural-language prompt; stored in audit table (could be accessed)	Medium	High	9	**COND-005-1:** Audit logging with access controls; prompts retained 180 days, access restricted to Compliance Officer
2	Genie response reveals low-count aggregate	E.g., "Members with X rare diagnosis: 1" reveals identity	Medium	Medium	6	**COND-005-3:** Monthly audit of result sets; TRB spot-checks 10 queries for low-count suppression
3	Unauthorized user queries member data	User credentials compromised or misused	Low	High	5	Access control via UC permissions; MFA on Databricks. Mitigated by standard identity controls.
4	Row-level filter bypass	User finds way to query unfiltered data	Low	High	5	**COND-005-2:** Test row filters with test identities; TRB spot-checks
5	User copies Genie result to unencrypted drive	Results exported outside Databricks	Low	Medium	3	**COND-005-4:** Training on data handling. Monitored via USB device restriction (IT controls).

4.2 Risk Mitigation (Conditions)

Condition ID	Mitigation	Effectiveness
COND-005-1	Log all Genie queries (prompt, generated SQL, result count) to system tables; retain 180 days; restrict prompt access to Compliance Officer + CISO	High—enables breach investigation & pattern analysis
COND-005-2	Row-level filtering enforced; TRB conducts test with 3 test identities to confirm masking works	High—prevents unauthorized row access
COND-005-3	Monthly audit of 10 random Genie queries; check result set for low-count suppression (e.g., "n < 5" not displayed)	Medium—catches problematic queries; relies on manual review
COND-005-4	All users complete "Databricks + HIPAA Data Handling" training before Genie access; refresher annually	Medium—awareness reduces accidental disclosure; enforcement via access control

---

5. Residual Risk Statement

After conditions are met, residual risk is LOW.

- **User Prompt PHI Leakage:** Mitigated by training + audit logging. Residual: User forgets training or deliberately discloses (very low likelihood).
- **Response Privacy:** Audit sampling catches most low-count issues. Residual: Unknown/hard-to-detect patterns (very low).
- **Unauthorized Access:** UC row filters + MFA reduce to baseline identity compromise risk (low for this organization).

Assumption: Acme Health Plan maintains standard IT security controls (patch management, endpoint protection, incident response). If these degrade, residual risk increases.

---

6. Compliance & Audit Notes

Regulatory Framework:
- HIPAA Security Rule § 164.312 (Technical Safeguards): Access controls, audit logging, encryption

- NIST 800-66 § 7 (Technical Safeguards Implementation): Logging, monitoring, access control

Acme Health Plan Policies:
- Data Governance Policy [POLICY-2024-DG]: Prohibits sharing PHI outside workspace without explicit approval
- User Training Policy [POLICY-2024-TRAINING]: Annual HIPAA training mandatory

Audit Trail Retention:
- Genie query audit logs: 180 days (retention per [POLICY-2024-RETENTION])
- Genie prompts: 180 days, access restricted
- Incident investigation: Logs preserved for 7 years

---

7. Recommendation

✓ **RECOMMEND APPROVAL WITH CONDITIONS**

Decision: Genie One is fit for PHI use when conditions (COND-005-1 through COND-005-4) are met and verified.

Approval Authority: TRB Board (unanimous vote required for PHI)

Next Step: TRB to issue Conditional Approval Letter by [date]. Requestor to execute conditions by [deadline]. TRB to verify before go-live.

Assessment Completed By:
Enterprise Architect
Signature: _____ Date: July 21, 2026

Reviewed By:
CISO
Signature: _____ Date: July 27, 2026

Classification: Internal – Synthetic Sample